

F20AN/21AN Coursework 1

Investigation of a Security Tool: Nessus

Joseph Emmanuel,

[REDACTED]

[REDACTED]

Contents

Introduction	3
Lab-Setup	3
Windows System Vulnerabilities and Misconfigurations	4
Nessus.....	4
Host Discovery	5
Basic Network Scan.....	6
Advanced Scan	9
Malware Scan	11
Conclusion.....	13
References	14
Appendix A: Credential Validation Scan	15
Appendix B: Detailed Scan Results from Report	16
Appendix C: Report Autopsy	17
Appendix D: Windows VM Vulnerabilities	21

Introduction

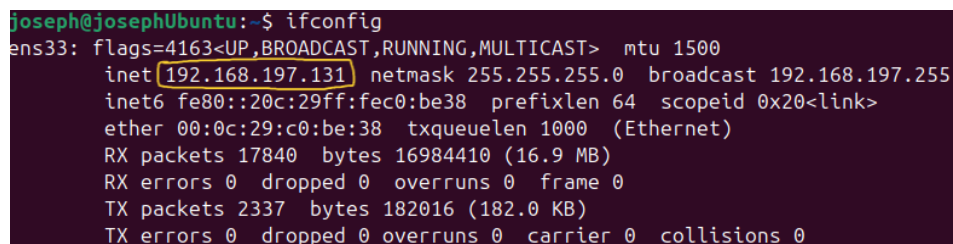
This report outlines the development and evaluation of an advanced network security lab designed to test the tool Nessus on a vulnerable Windows 10 virtual machine. The Ubuntu virtual machine running Nessus is designed to act as an organization's admin, while the Windows 10 virtual machine is an employee within the organization.

Lab-Setup

The virtual lab was created using VMware Workstation Pro, where Ubuntu and Windows operating systems were installed on separate virtual machines (VMs). The VMs are configured with NAT (Network Address Translation), allowing them to share the host computer's IP address for Internet access.

This Setup has two main benefits:

- **Internal Communication:** The NAT configuration creates a private virtual network that enables the two VMs to communicate with each other securely. This is crucial since the victim machine and the admin machine need to be on the same virtual subnet to be scanned using the tool.
- **External Access:** The NAT configuration also allows the VMs to access the internet to download software while keeping the internal network isolated. Below are screenshots to confirm IP assignments and connectivity through successful ping tests.

A terminal window with a dark purple background. The prompt is 'joseph@josephUbuntu:~\$'. The command 'ifconfig' has been executed. The output shows details for the 'ens33' interface, including flags, MTU, IP address (192.168.197.131), netmask, broadcast address, and various statistics. The IP address '192.168.197.131' is highlighted with a yellow box.

```
joseph@josephUbuntu:~$ ifconfig
ens33: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 1500
    inet 192.168.197.131 netmask 255.255.255.0  broadcast 192.168.197.255
    inet6 fe80::20c:29ff:fec0:be38 prefixlen 64  scopeid 0x20<link>
    ether 00:0c:29:c0:be:38 txqueuelen 1000  (Ethernet)
    RX packets 17840  bytes 16984410 (16.9 MB)
    RX errors 0  dropped 0  overruns 0  frame 0
    TX packets 2337  bytes 182016 (182.0 KB)
    TX errors 0  dropped 0  overruns 0  carrier 0  collisions 0
```

Figure 1. 1

```
Ethernet adapter Ethernet0:

Connection-specific DNS Suffix  . : localdomain
Link-local IPv6 Address . . . . . : fe80::d2c1:10a4:dbc7:bec8%6
IPv4 Address. . . . . : 192.168.197.133
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . : 192.168.197.2
```

Figure 1. 2

```
joseph@josephUbuntu:~$ ping 192.168.197.133
PING 192.168.197.133 (192.168.197.133) 56(84) bytes of data.
64 bytes from 192.168.197.133: icmp_seq=1 ttl=128 time=0.789 ms
64 bytes from 192.168.197.133: icmp_seq=2 ttl=128 time=0.887 ms
64 bytes from 192.168.197.133: icmp_seq=3 ttl=128 time=0.903 ms
64 bytes from 192.168.197.133: icmp_seq=4 ttl=128 time=0.808 ms
64 bytes from 192.168.197.133: icmp_seq=5 ttl=128 time=0.704 ms
```

Figure 1. 3

```
C:\Users\Kate>ping 192.168.197.131

Pinging 192.168.197.131 with 32 bytes of data:
Reply from 192.168.197.131: bytes=32 time<1ms TTL=64
Reply from 192.168.197.131: bytes=32 time<1ms TTL=64
Reply from 192.168.197.131: bytes=32 time<1ms TTL=64
Reply from 192.168.197.131: bytes=32 time<1ms TTL=64
```

Figure 1. 4

Windows System Vulnerabilities and Misconfigurations

To evaluate the capabilities of Nessus, several intentional vulnerabilities and misconfigurations were introduced. These were designed to test whether Nessus could successfully detect them and provide appropriate remediation guidance. The vulnerabilities included:

- Installing outdated and deprecated software
- Disabling Windows Firewall and Windows Defender
- Exposing all ports and not updating the victim machine
- Disabling User Account Control (UAC)
- Introducing Benign Malware for testing

Nessus

Nessus is a widely used vulnerability assessment tool developed by Tenable, designed to help identify and evaluate security vulnerabilities within computer systems, networks, and

applications. It enables system administrators to scan for misconfigurations, outdated software, missing patches, and known exploits that could be leveraged by attackers (Tenable, 2023). Its ability to provide detailed vulnerability information, including risk scores and remediation guidance, makes it a valuable tool in proactive threat management and compliance auditing.

Host Discovery

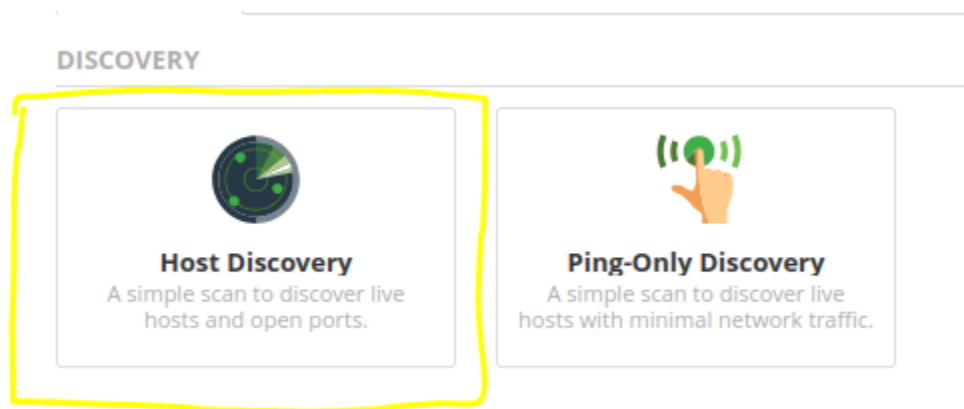


Figure 1. 5

The first scan that can be done is within the discovery section called “Host Discovery”. The scan is used to identify which devices in the subnet are active and reachable. The scan doesn’t analyze vulnerabilities but only checks if systems respond to network pings.

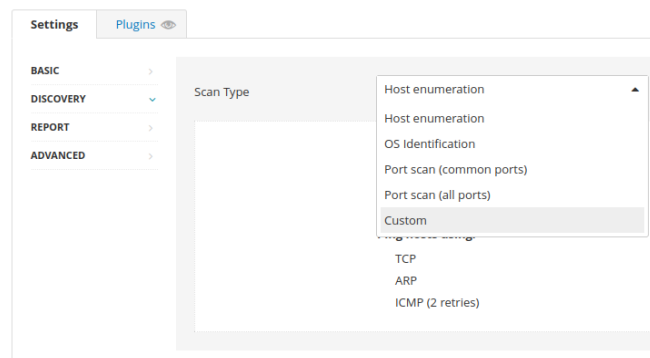


Figure 1. 6

Figure 1.6 also shows the host discovery scan having many sub templates such as host enumeration (simple ping), host identification (identifies the host and collects information about it), port scanning. Whatever the sub-template, the scan utilizes TCP, ICMP, and ARP requests to conduct these scans and probe the machine if alive.

HostDiscovery Configure Audit Trail

← Back to All Scans

Hosts 7 Vulnerabilities 2 History 1

Filter Search Hosts 7 Hosts

Host	Ports
192.168.197.254	
192.168.197.133	135, 139, 445, 49664, 49665, 49666, 49667, 49668, 49669, 49670
192.168.197.131	
192.168.197.130	
192.168.197.129	
192.168.197.2	
192.168.197.1	

Figure 1. 7

Figure 1.7 shows the hosts discovered within the subnet using this scan. The .133, and .129 are the Windows VMs. The .131 is the ubuntu machine running the scan. The .254 is the virtual gateway, and the .2 is the DHCP service.

The machine with the exposed ports is the victim machine running in the subnet.

Basic Network Scan

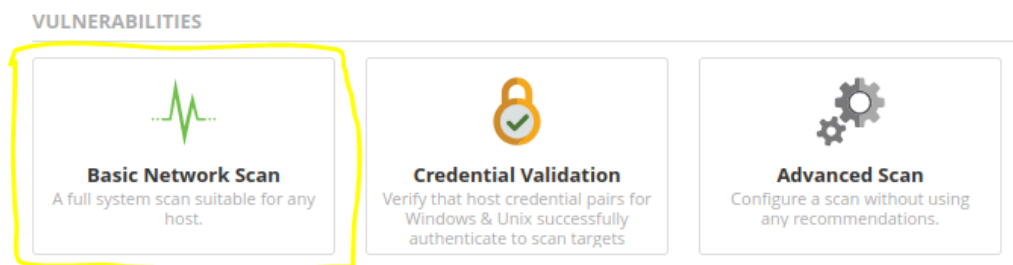


Figure 1. 8

A basic network Scan in Nessus is a predefined vulnerability assessment that scans the target systems for common security issues and misconfigurations using default plugins. Essentially a very simple scan that is not very customizable and gives fast results.

Settings Credentials Plugins

CATEGORIES Host

Filter Credentials

SSH

Windows

Windows

Authentication method Password

Username Kate

Password

Domain

Figure 1. 9

Figure 1.9 shows the Credentials tab for the scan, which allows the user or administrator to supply login credentials to specific services or systems. This enables Nessus to perform a much deeper, authenticated scan that can uncover additional vulnerabilities or misconfigurations that are not visible through unauthenticated scanning.

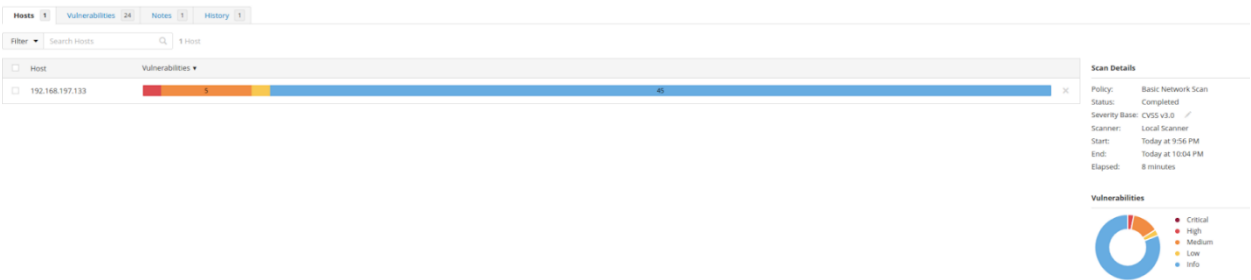


Figure 1. 10

Figure 1.10 shows the results of the Basic Network Scan, where the discovered vulnerabilities are categorized by severity from Low to Critical, excluding informational findings. The visual bar and pie chart provide a quick overview of the overall risk posture of the scanned system, and further information can be found by navigating to the Vulnerabilities tab, where each finding can be accessed, including descriptions, CVE identifiers, severity scores, and recommended remediation steps.

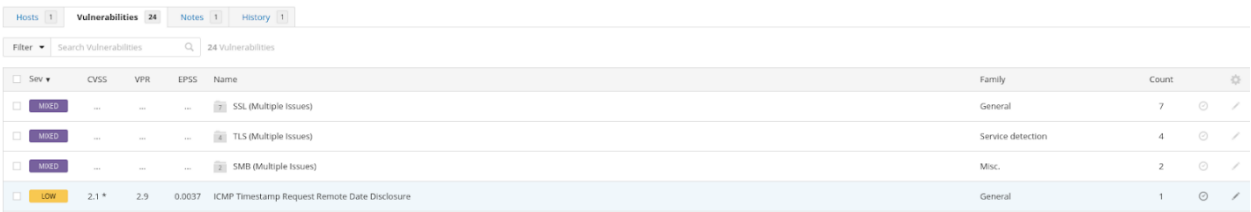


Figure 1. 11

Figure 1.11 shows some of the vulnerabilities discovered, and clicking on them reveals more details regarding the vulnerabilities and what they are

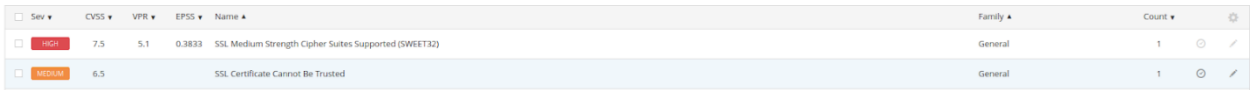


Figure 1. 12

Figure 1.12 highlights a high-severity vulnerability related to SSL configuration. Specifically, the scan detected that the host supports medium-strength cipher suites (SWEET32), which are known to be susceptible to cryptographic attacks. Clicking on the vulnerability gives further information regarding what it is and how to solve it.

HIGH
SSL Medium Strength Cipher Suites Supported (SWEET32)

Description

The remote host supports the use of SSL ciphers that offer medium strength encryption. Nessus regards medium strength as any encryption that uses key lengths at least 64 bits and less than 112 bits, or else that uses the 3DES encryption suite.

Note that it is considerably easier to circumvent medium strength encryption if the attacker is on the same physical network.

Solution

Reconfigure the affected application if possible to avoid use of medium strength ciphers.

See Also

<http://www.nessus.org/u/df5559f5>
<https://sweet32.info>

Output

```

Medium Strength Ciphers (> 64-bit and < 112-bit key, or 3DES)
-----
Name                Code      KEK      Auth      Encryption      MAC
-----
DES-CBC3-SHA        0x00, 0x0A  RSA      RSA      3DES-CBC (168)  SHA1

The fields above are :
(Tenable_ciphertext)
(cipher_id_code)
Key=key_exchange
Auth=authentication
Encrypt=symmetric encryption method)
MAC=message authentication code)
(export_flag)

To see debug logs, please visit individual host

```

Port	Hosts
3389 / hp / mscdp	192.168.197.133

Figure 1. 13

Figure 1.13 shows information regarding vulnerability and even provides references to the specific vulnerability, which could be very helpful in an organizational setting where time is of the essence.

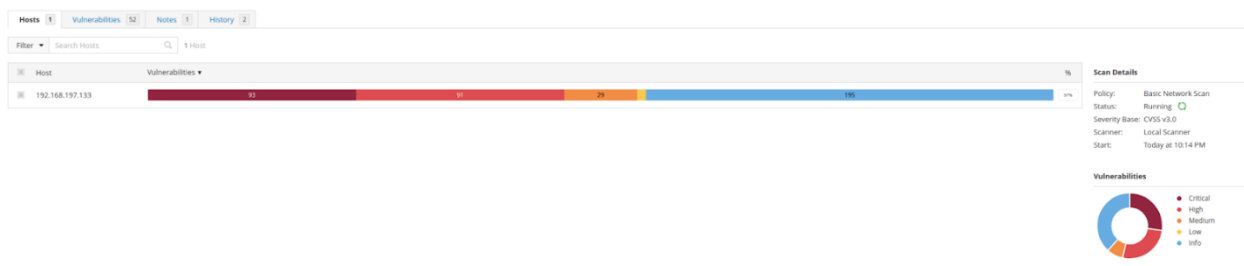


Figure 1. 14

Figure 1.14 shows the results of a Basic Network Scan run with Windows credentials enabled. The use of valid credentials allows the tool to perform a much deeper scan, which provides visibility into system-level vulnerabilities that would remain hidden in a regular non-authenticated scan.

As seen in the figure, the number of detected vulnerabilities, especially in the Critical and High categories, has increased significantly, highlighting the importance of credentialed scanning for accurate vulnerability assessment.

Hosts1

Vulnerabilities52

Notes1

History2

Search Vulnerabilities

195 Vulnerabilities

Sev	CVSS	VPR	EPSS	Name	Family	Count
CRITICAL	10.0	*		Firefox < 14.0 Multiple Vulnerabilities	Windows	1
CRITICAL	10.0	*		Firefox < 15.0 Multiple Vulnerabilities	Windows	1
CRITICAL	10.0	*		Firefox < 16.0 Multiple Vulnerabilities	Windows	1

Figure 1. 15: Basic Scan with credentials found increased critical vulnerabilities

Figure 1.15 highlights the critical vulnerabilities related to downloading a deprecated version of Mozilla Firefox on the victim system.

Advanced Scan

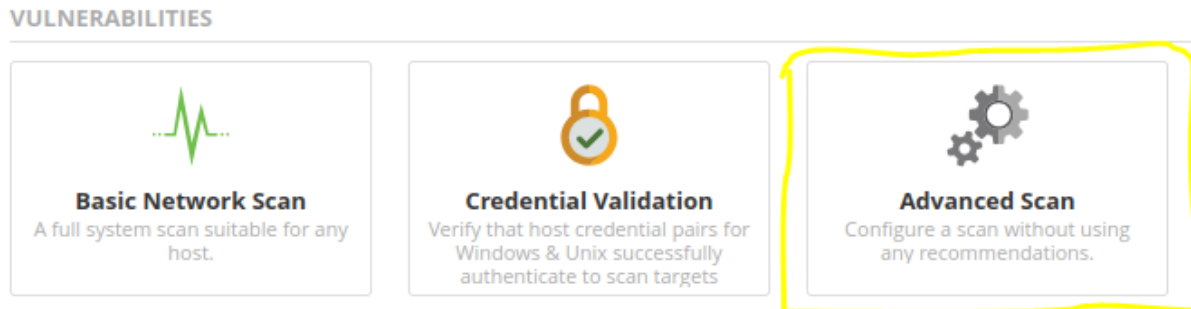


Figure 1. 16

The Advanced Scan is one of Nessus's most flexible and customizable scanning options. It allows the user to selectively choose exactly what aspects they would like to scan for, ranging from malware detection and web application vulnerabilities to missing software updates. Essentially, it acts as an "all-in-one" scan, combining features from many of the pre-defined scans Nessus offers into a single comprehensive assessment.

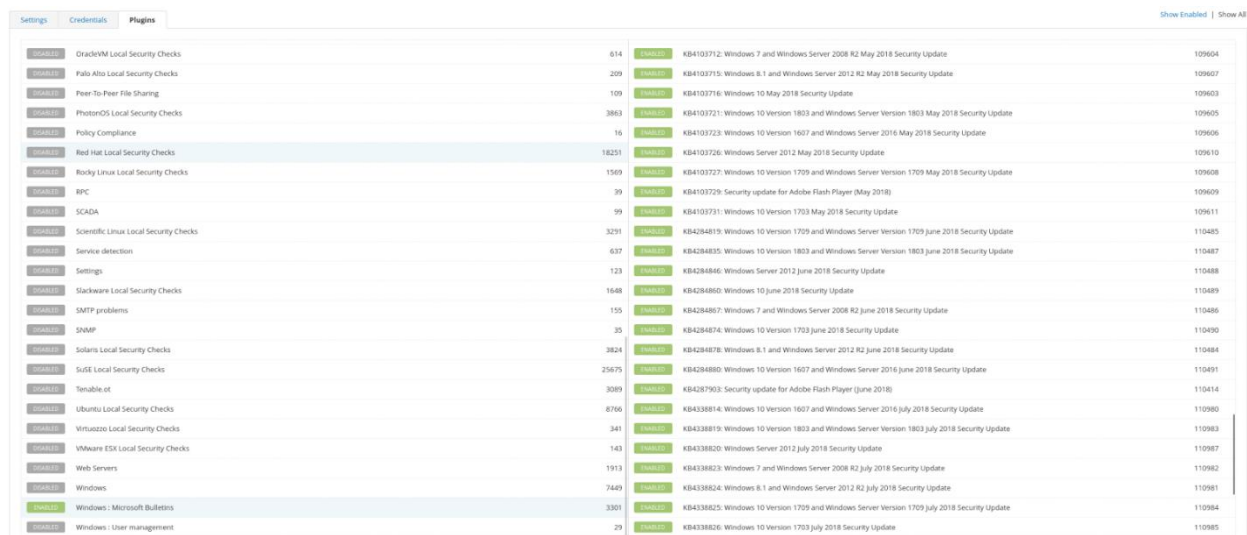


Figure 1. 17

Figure 1.17 displays the plugin customization options available in an Advanced Scan within Nessus. On the left side are various general plugin categories, while the right-side lists more specific individual plugins associated with each category. Users can selectively enable or disable these plugins to fine-tune the scanning process, allowing them to target very specific

vulnerabilities or security issues within the scanned system. The success and efficiency of a scan depends on the choice of plug-ins chosen. In this case, only one plugin was selected to scan just basic information regarding the target system software version, etc., as many of the other plugins were targeted more towards other OSs and software.

The user would also need to supply basic credentials to log into the system to conduct these deep scans.

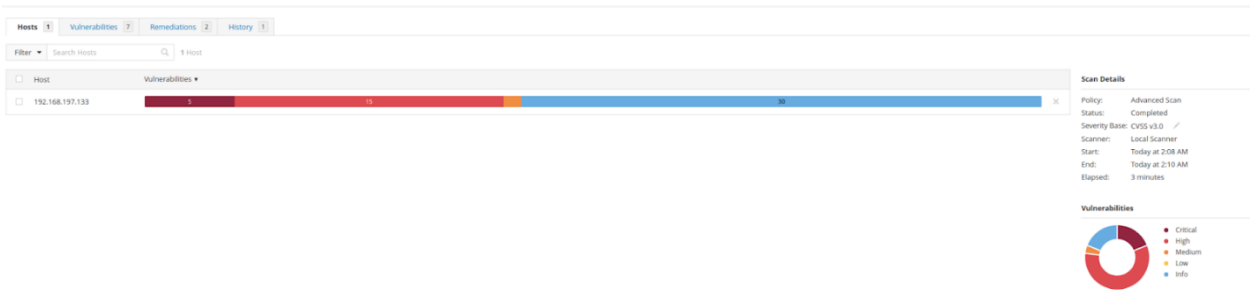


Figure 1. 18

Figure 1.18 shows the scan that was run and the information it found which is comparatively less than the basic scan due to the customization of plugins that were selected.



Figure 1. 19

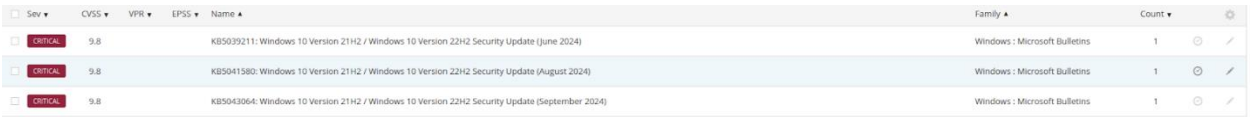


Figure 1. 20

Figure 1.20 shows certain missing patches critical to the security of the system, and clicking on them further shows solutions and CVEs related to vulnerability, which can be used to either patch it or circumvent it.

Malware Scan

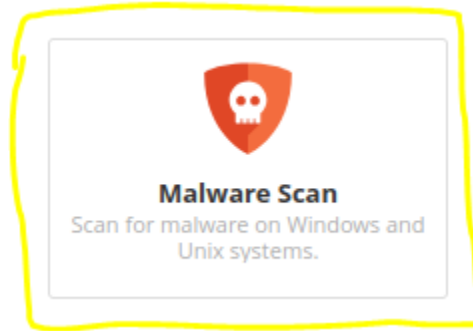


Figure 1. 21

The Nessus Malware Scan is designed to detect malware such as backdoors, trojans, and suspicious files by scanning the file system, registry entries, and running processes. This scan also relies on provided credentials to conduct a deep analysis of the system and identify known malware signatures.

A screenshot of the Nessus Malware Settings page. At the top, "Malware Settings" is the section header, and "Scan for malware" is a toggle switch that is turned on. Below this, the "Hash and Allowlist Files" section contains three upload options: "Custom Netstat IP Threat List" with a link to "Add File", "Provide your own list of known bad MD5/SHA1/SHA256 hashes:" with a file named "badhashes.txt" and a close button, and "Provide your own list of known good MD5/SHA1/SHA256 hashes:" with a link to "Add File". The "Hosts file allowlist" section has a link to "Add File". At the bottom, the "Yara Rules" section shows a file named "directory-1.yar" with a close button. Each upload area includes a brief description of the file type and its use in the scan.

Figure 1. 22

Figure 1.22 shows two files being provided to the Nessus Malware Scan. The first is a "known bad hash" file containing a list of malware file hashes. Nessus uses this list to check whether any files on the scanned system match these known malicious signatures. The second file is a YARA rule file, which defines specific patterns and strings that identify suspicious or

malicious code. YARA rules are useful for detecting more complex or custom malware that may not yet be available in traditional signature databases.

In this example, the hashes and YARA rules being passed are for benign malware from the EICAR test file, which is used to verify if anti-malware detection systems are functioning correctly.

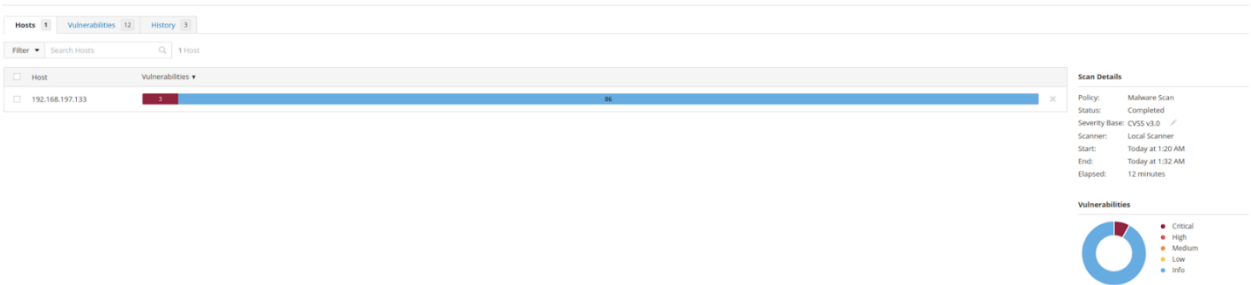


Figure 1. 23

Figure 1.23 shows the overall scan and has detected 3 critical vulnerabilities and some info. When digging further into these vulnerabilities, there seem to be some malicious files that were discovered during the scan.



Figure 1. 24

Figure 1.24 shows three critical issues detected during the malware scan. The first is a tampered hosts file, which indicates a potential compromise that could lead to traffic redirection to malicious sites. The second is a YARA-based detection, where a malicious file was identified using the custom YARA rule (in this case, it's the EICAR test file)



Figure 1. 25

The Third one is under the Microsoft vulnerabilities, and Figure 1.25 shows that clicking on it seems to show a malicious file that was discovered from the “known bad hash” file that was provided (Again, it being the EICAR test file).

Conclusion

Overall, the use of Nessus in this lab proved to be highly effective and insightful. It provided a clear view of system vulnerabilities, misconfigurations, and even malware through various customizable scans. The tool was easy to use, informative, and offered practical results that could significantly enhance real-world security assessments. Overall, a great experience and a valuable learning opportunity.

References

Settings Configuration (2018) *Tenable.com*. Available at: <https://docs.tenable.com/quick-reference/nessus-scan-tuning/Content/Nessus-Scan-Tuning/SettingsConfiguration.htm>.

Considerations (2024) *Tenable.com*. Available at: <https://docs.tenable.com/quick-reference/nessus-scan-tuning/Content/Nessus-Scan-Tuning/Considerations.htm> (Accessed: 3 April 2025).

Credentials Configuration (2024) *Tenable.com*. Available at: <https://docs.tenable.com/quick-reference/nessus-scan-tuning/Content/Nessus-Scan-Tuning/CredentialsConfiguration.htm> (Accessed: 3 April 2025).

Tenable, T. (2019) *How To: Run Your First Vulnerability Scan with Nessus, Tenable®*. Available at: <https://www.tenable.com/blog/how-to-run-your-first-vulnerability-scan-with-nessus>.

Good, J. (2020) 'Nessus Vulnerability Scanner Tutorial (Cyber Security Tools)', *YouTube*. Available at: <https://www.youtube.com/watch?v=x87gbgQD4eg>.

David Bombal (2024) *Install Nessus for Free and scan for Vulnerabilities (New Way)*, *YouTube*. Available at: <https://www.youtube.com/watch?v=Gy-aPBb0djk> (Accessed: 2 October 2024).

Tenable (2023) *Nessus Product Family, Tenable®*. Available at: <https://www.tenable.com/products/nessus>.

Scan and Policy Templates (Nessus) (no date) *docs.tenable.com*. Available at: <https://docs.tenable.com/nessus/Content/ScanAndPolicyTemplates.htm>.

Joshua's Tech Tips (2024) *How To Perform Vulnerability Scans using Nessus - Part 1*, *YouTube*. Available at: https://www.youtube.com/watch?v=ij4_LK88fSU (Accessed: 3 April 2025).

Joshua's Tech Tips (2024) *How To Perform Vulnerability Scans using Nessus Part 2*, *YouTube*. Available at: <https://www.youtube.com/watch?v=NfnU7WeDsJw> (Accessed: 3 April 2025).

Appendix A: Credential Validation Scan

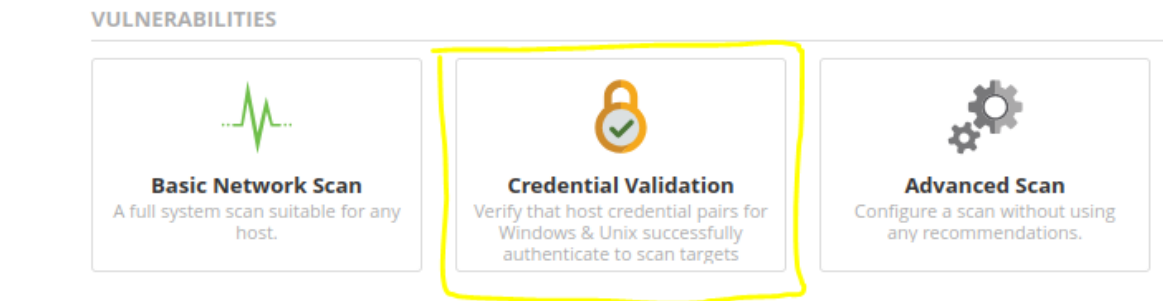


Figure 1. 26

The Credential Validation scan verifies whether the supplied credentials are valid and whether Nessus can successfully authenticate into the target system.

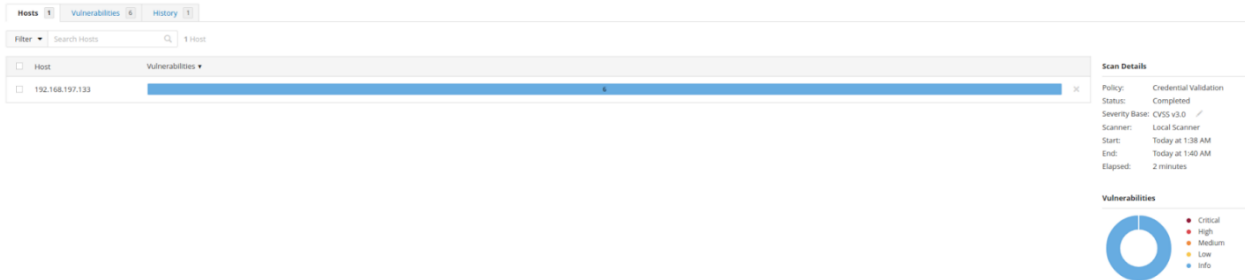


Figure 1. 27

Figure 1.27 shows the results after the scan has run and has collected some information on the target.

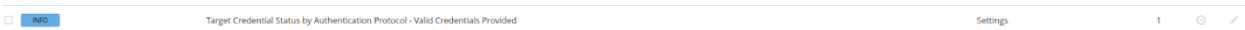


Figure 1. 28

Figure 1.28 shows one of the pieces of information verifying that the supplied credentials are indeed correct and that it was able to log in to perform the scan.

Appendix B: Detailed Scan Results from Report

Below are screenshots from various reports showcasing the different vulnerabilities that were introduced to the Windows machine during the lab setup. From deprecated software to malware, all were detected during the different scanning processes.

CRITICAL	9.8	6.7	0.0435	88461	Firefox < 44 Multiple Vulnerabilities
CRITICAL	9.8	8.9	0.8551	89875	Firefox < 45 Multiple Vulnerabilities
MEDIUM	6.8*	5.8	0.0175	69476	FileZilla Client < 3.7.2 SFTP Integer Overflow
MEDIUM	6.8*	5.9	0.0114	69494	FileZilla Client < 3.7.3 Multiple Vulnerabilities
MEDIUM	5.1*	5.9	0.0158	58000	Yahoo! Messenger < 11.5.0.155 CYImage::LoadJPG Method JPG File Handling Remote Integer Overflow
HIGH	7.8	6.7	0.0374	178245	Microsoft Paint 3D Code Execution (July 2023)
HIGH	7.8	5.9	0.0056	158710	Microsoft Paint 3D Code Execution (March 2022)
INFO	N/A	-	-	104856	Malicious Process Detection: Authenticode Not Signed
INFO	N/A	-	-	104854	Malicious Process Detection: Authenticode Signed Bad Date
INFO	N/A	-	-	10394	Microsoft Windows SMB Log In Possible
INFO	N/A	-	-	10400	Microsoft Windows SMB Registry Remotely Accessible
INFO	N/A	-	-	10456	Microsoft Windows SMB Service Enumeration
INFO	N/A	-	-	10396	Microsoft Windows SMB Shares Access
INFO	N/A	-	-	10395	Microsoft Windows SMB Shares Enumeration
CRITICAL	9.8	-	-	200343	KB5039211: Windows 10 Version 21H2 / Windows 10 Version 22H2 Security Update (June 2024)
CRITICAL	9.8	-	-	205452	KB5041580: Windows 10 Version 21H2 / Windows 10 Version 22H2 Security Update (August 2024)
CRITICAL	9.8	-	-	206894	KB5043064: Windows 10 Version 21H2 / Windows 10 Version 22H2 Security Update (September 2024)
MEDIUM	6.5	-	-	51192	SSL Certificate Cannot Be Trusted
MEDIUM	6.5	-	-	57582	SSL Self-Signed Certificate

Figure 1. 29

Appendix C: Report Autopsy

Below are snippets of the report format the was generated using autopsy after the scans were finished.

61715 - Firefox < 15.0 Multiple Vulnerabilities	-
Synopsis	
The remote Windows host contains a web browser that is affected by multiple vulnerabilities.	
Description	
The installed version of Firefox is earlier than 15.0 and thus, is potentially affected by the following security issues :	
- An error exists related to 'Object.defineProperty' and the location object and can allow cross-site scripting attacks. (CVE-2012-1956) - Unspecified memory safety issues exist. (CVE-2012-1970, CVE-2012-1971) - Multiple use-after-free errors exist. (CVE-2012-1972, CVE-2012-1973, CVE-2012-1974, CVE-2012-1975, CVE-2012-1976, CVE-2012-3956, CVE-2012-3957, CVE-2012-3958, CVE-2012-3959, CVE-2012-3960, CVE-2012-3961, CVE-2012-3962, CVE-2012-3963, CVE-2012-3964) - An error exists related to 'about:newtab' and the browser's history. This error can allow a newly opened tab to further open a new window and navigate to the privileged 'about:newtab' page leading to possible privilege escalation. (CVE-2012-3965) - An error exists related to bitmap (BMP) and icon (ICO) file decoding that can lead to memory corruption causing application crashes and potentially arbitrary code execution. (CVE-2012-3966) - A use-after-free error exists related to WebGL shaders. (CVE-2012-3968) - A buffer overflow exists related to SVG filters. (CVE-2012-3969) - A use-after-free error exists related to elements having 'requiredFeatures' attributes. (CVE-2012-3970) - A 'Graphite 2' library memory corruption error exists. (CVE-2012-3971) - An XSLT out-of-bounds read error exists related to 'format-number'. (CVE-2012-3972) - Remote debugging is possible even when disabled and the 'HTTPMonitor' extension is enabled. (CVE-2012-3973) - The installer can be ticked into running unauthorized executables. (CVE-2012-3974) - The DOM parser can unintentionally load linked resources in extensions. (CVE-2012-3975) - Incorrect SSL certificate information can be displayed in the address bar when two 'onLocationChange' events fire out of order. (CVE-2012-3976) - Security checks related to location objects can be bypassed if crafted calls are made to the browser chrome code. (CVE-2012-3978) - Calling 'eval' in the web console can allow injected code to be executed with browser chrome privileges. (CVE-2012-3980) - SPDY's request header compression leads to information leakage, which can allow private data such as session cookies to be extracted, even over an SSL connection. (CVE-2012-4930)	

Figure 1. 30

Figure 1.30 shows the synopsis and the description of what the vulnerability is in detail.

See Also

<http://www.securityfocus.com/archive/1/524145/30/0/threaded>
<https://www.mozilla.org/en-US/security/advisories/mfsa2012-57/>
<https://www.mozilla.org/en-US/security/advisories/mfsa2012-58/>
<https://www.mozilla.org/en-US/security/advisories/mfsa2012-59/>
<https://www.mozilla.org/en-US/security/advisories/mfsa2012-60/>
<https://www.mozilla.org/en-US/security/advisories/mfsa2012-61/>
<https://www.mozilla.org/en-US/security/advisories/mfsa2012-62/>
<https://www.mozilla.org/en-US/security/advisories/mfsa2012-63/>
<https://www.mozilla.org/en-US/security/advisories/mfsa2012-64/>
<https://www.mozilla.org/en-US/security/advisories/mfsa2012-65/>
<https://www.mozilla.org/en-US/security/advisories/mfsa2012-66/>
<https://www.mozilla.org/en-US/security/advisories/mfsa2012-67/>
<https://www.mozilla.org/en-US/security/advisories/mfsa2012-68/>
<https://www.mozilla.org/en-US/security/advisories/mfsa2012-69/>
<https://www.mozilla.org/en-US/security/advisories/mfsa2012-70/>
<https://www.mozilla.org/en-US/security/advisories/mfsa2012-72/>
<https://www.mozilla.org/en-US/security/advisories/mfsa2012-73/>

Solution

Upgrade to Firefox 15.0 or later.

Risk Factor

Critical

CVSS v2.0 Base Score

10.0 (CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C)

CVSS v2.0 Temporal Score

7.4 (CVSS2#E:U/RL:OF/RC:C)

Figure 1. 31

Figure 13.1 shows certain references to the vulnerability that was discovered with the solution on how to remediate it and its associated risk factor.

CVE	CVE-2012-1956
CVE	CVE-2012-1970
CVE	CVE-2012-1971
CVE	CVE-2012-1972
CVE	CVE-2012-1973
CVE	CVE-2012-1974
CVE	CVE-2012-1975
CVE	CVE-2012-1976
CVE	CVE-2012-3956
CVE	CVE-2012-3957
CVE	CVE-2012-3958
CVE	CVE-2012-3959
CVE	CVE-2012-3960
CVE	CVE-2012-3961
CVE	CVE-2012-3962
CVE	CVE-2012-3963
CVE	CVE-2012-3964
CVE	CVE-2012-3965
CVE	CVE-2012-3966
CVE	CVE-2012-3968
CVE	CVE-2012-3969
CVE	CVE-2012-3970
CVE	CVE-2012-3971
CVE	CVE-2012-3972
CVE	CVE-2012-3973
CVE	CVE-2012-3974
CVE	CVE-2012-3975
CVE	CVE-2012-3976
CVE	CVE-2012-3978
CVE	CVE-2012-3980

Figure 1. 32

Figure 13.2 shows the CVE associated with the vulnerabilities and the exploits that can be used against them.

Plugin Information

Published: 2012/08/29, Modified: 2019/12/04

Plugin Output

tcp/445/cifs

```
Path : C:\Program Files (x86)\Mozilla Firefox  
Installed version : 3.6.12  
Fixed version : 15.0
```

Figure 1. 33

Figure 1.33 shows the plugin information used to detect this vulnerability and shows the output which essentially shows where this file is located on the machine.

Appendix D: Windows VM Vulnerabilities

Below are snippets of the vulnerabilities induced to the victim Windows Host



Figure 1.34

Figure 1.34 shows that real-time and cloud-delivered protection were turned off, exposing VM to malware.

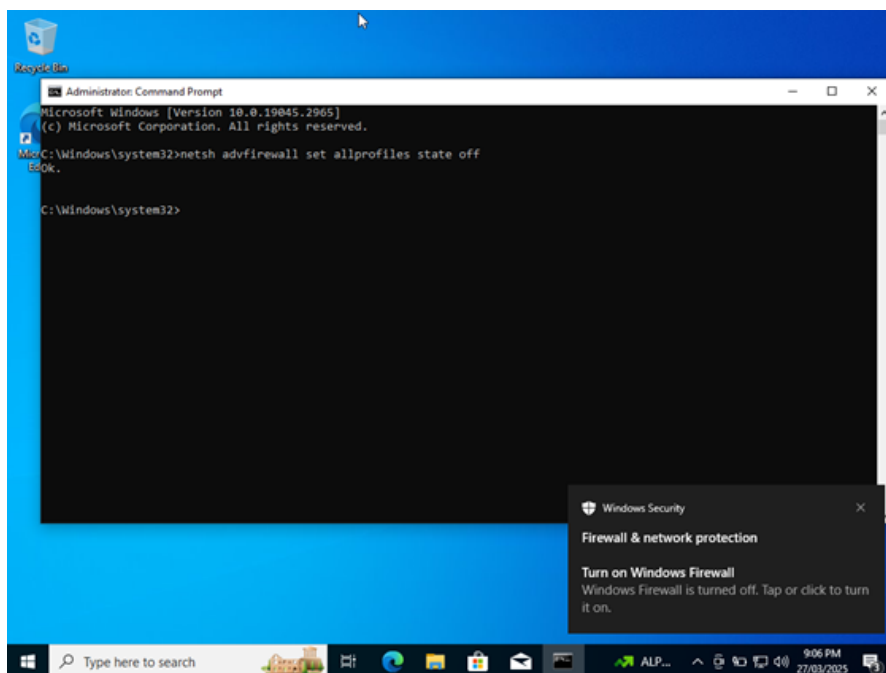


Figure 1.35

Figure 1.35 shows that all firewall profiles were disabled using netsh, opening the system to unauthorized access.

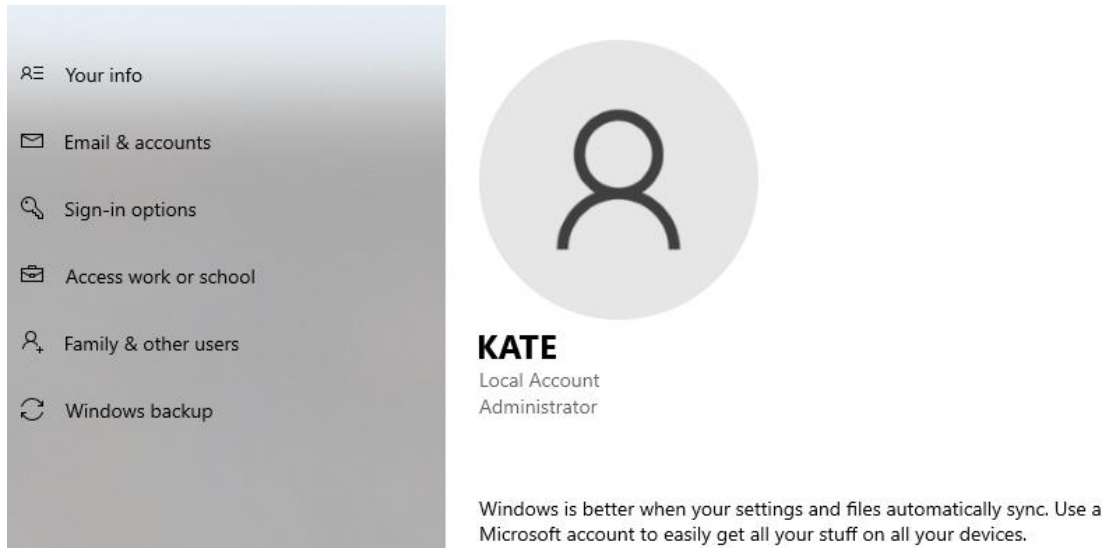


Figure 1.36

Figure 1.36 shows a user (Kate) with weak credentials (Password = password) being added and granted administrator privileges.

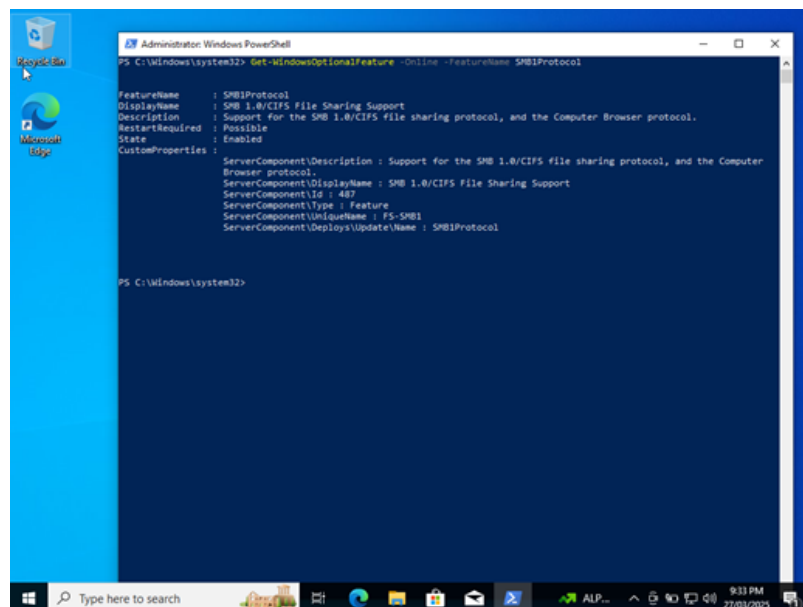


Figure 1.37

Figure 1.37 shows that legacy SMBv1 protocol known for vulnerabilities were enabled

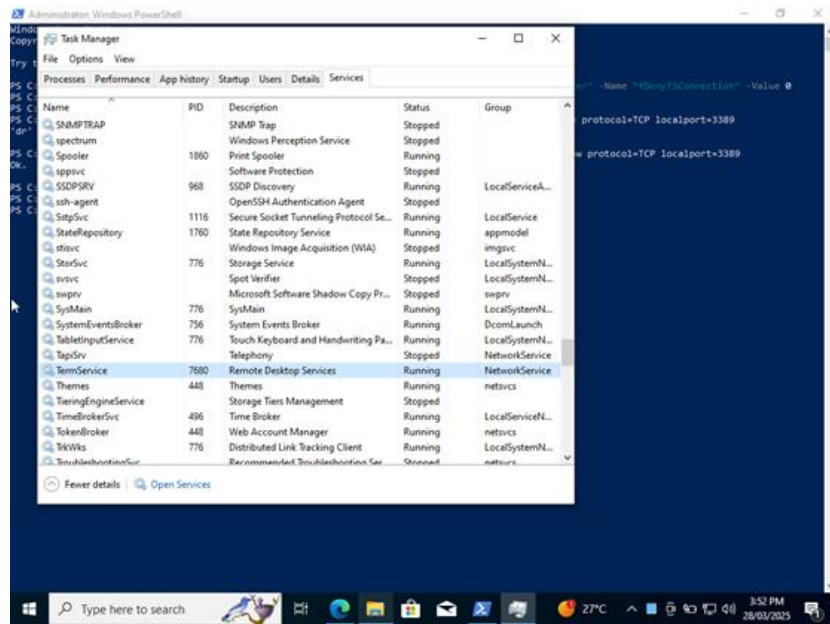


Figure 1.38

Figure 1.38 confirmed that RDP is running, opening port 3389 for remote login attacks.

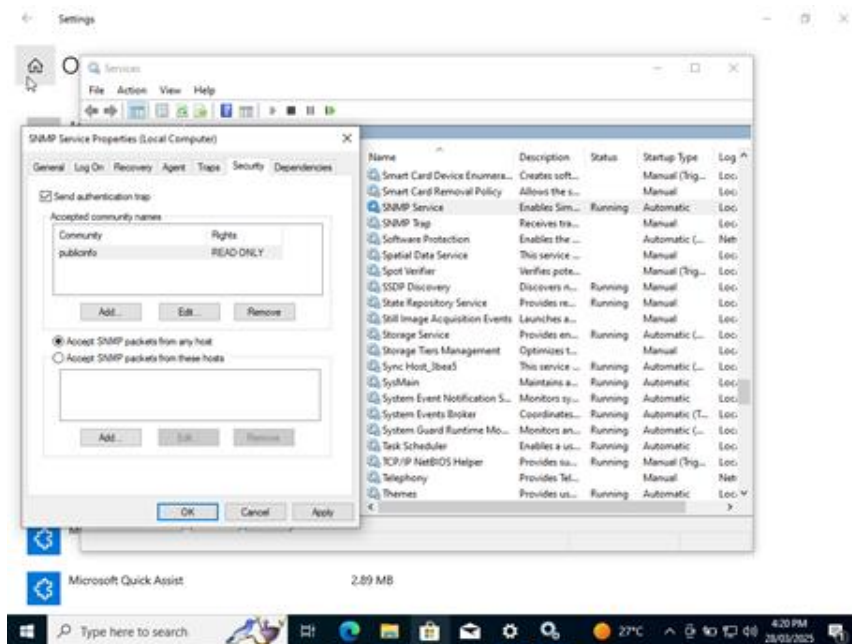


Figure 1.39

Figure 1.39 shows that SNMP with default 'public' string, allowing remote enumeration of system info were enabled

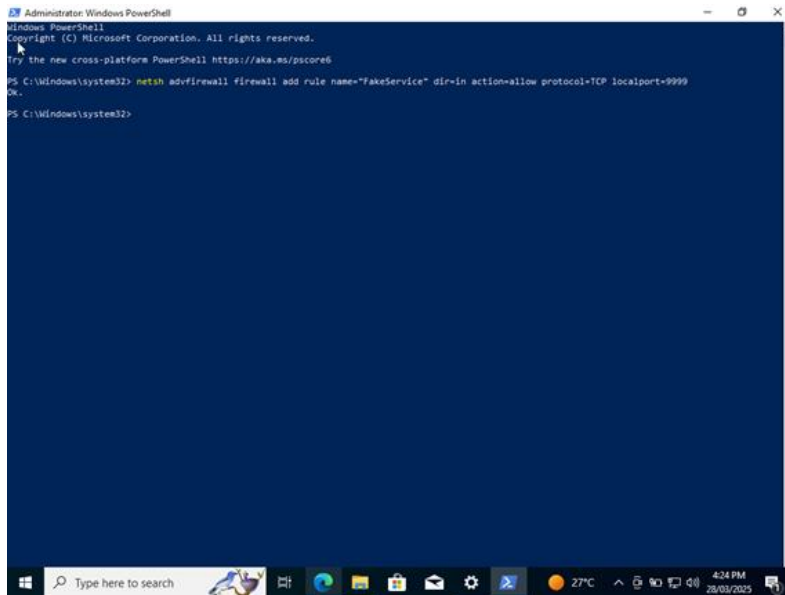


Figure 1.40

Figure 1.40 shows an opened port 9999 in firewall using a fake service to simulate unused exposed ports

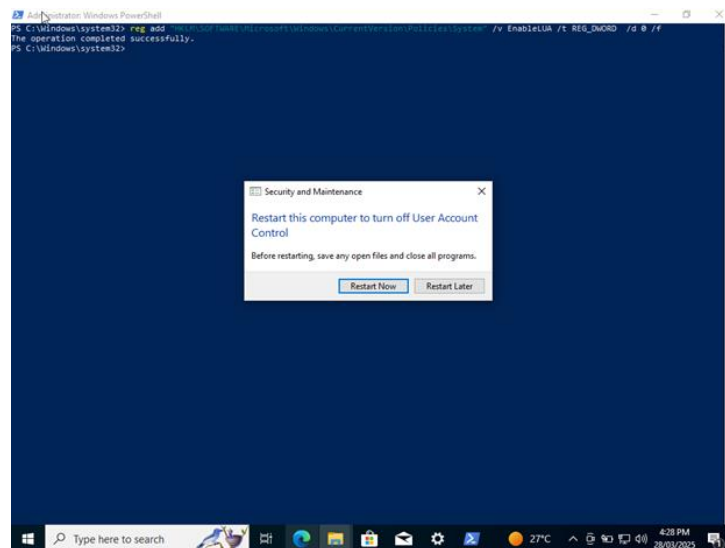


Figure 1.41

Figure 1.41 shows used registry modification to completely disable UAC, reducing prompt-based security.